

ISO 27001 Compliance Auditor

Automated Annex A gap analysis, real-time compliance
visibility and actionable remediation roadmaps

93

ANNEX A CONTROLS

47

TELEMETRY-DRIVEN

4

CONTROL THEMES

1

PDF DELIVERABLE

Document	Overview and User Guide
Application	ISO 27001 Compliance Auditor v1.0
Framework	ISO/IEC 27001:2022 Annex A (93 controls)
Stack	Python - Streamlit, Pandas, Plotly, FPDF2 - PowerShell 5.1+
Audience	Information security teams, system administrators, internal auditors
Issued	08 August 2026

1. What this application does

Auditing a system against ISO/IEC 27001 Annex A is normally a manual exercise: an auditor works through a spreadsheet of controls, interviews administrators, takes screenshots of settings, and assembles a report by hand. It is slow, it is inconsistent between auditors, and by the time the report is written the evidence is already out of date.

The ISO 27001 Compliance Auditor automates the technical half of that work. A read-only PowerShell collector inventories a Windows host; the web application evaluates that evidence against a defined Annex A baseline, assigns a risk level to every gap, and produces a prioritised remediation roadmap and a management-ready PDF. What took days of spreadsheet work takes minutes, and the result is repeatable - the same configuration always yields the same verdict.

The five capabilities

Capability	What it does
Data ingestion	Parses system configuration reports in JSON or CSV. Auto-detects layout, coerces string values into proper types, flattens nested structures into dotted keys and reports which sections are missing.
Audit engine	Cross-references the ingested telemetry against the Annex A baseline, evaluating every control through declarative checks. Assigns PASS, PARTIAL, FAIL, MANUAL, NO DATA or N/A, plus a High / Medium / Low risk level.
Compliance dashboard	Plotly gauge, status donut, per-theme stacked bars, a radar against a 75% target and a risk histogram - all recalculating live as attestations change.
Remediation roadmap	Orders every gap by risk, groups it into delivery phases with target windows, and attaches step-by-step technical fixes an administrator can act on directly.
PDF export	Generates a professional audit report - scorecard cover, executive summary, theme breakdown, the full 93-control register, the roadmap and a telemetry appendix.

Design principles

Three decisions shape how the tool behaves, and they are worth understanding before you read a score:

- **Absence of evidence is not evidence of compliance.** When telemetry for a control is missing, the control reports NO DATA - never PASS. A collector run without administrator rights produces a visibly incomplete audit rather than a misleadingly clean one.
- **Partial credit is real.** A control with six checks where five pass is not equivalent to one where none pass. PARTIAL carries half weight, so progress is visible between audits.
- **Coverage is reported alongside the score.** A 100% score derived from three controls is not a 100% score. The app states what fraction of the 93 controls produced a real verdict and warns when that fraction is too low to be meaningful.

2. How it works

The pipeline has four stages. Each is a separate module, so the audit logic can be used from a script or a CI job without the web interface.



Figure 1 - The four-stage assessment pipeline.

The control baseline

The Annex A baseline lives in `data/iso27001_baseline.json` - a plain data file, not code. Every control declares its theme, objective, inherent severity, remediation steps and a list of checks. A check names a telemetry field, an operator and an expected value:

```
{
  "id": "A.8.5", "title": "Secure authentication",
  "theme": "Technological", "mode": "automated", "severity": "High",
  "checks": [
    { "field": "identity.mfa_enabled", "op": "truthy",
      "label": "Multi-factor authentication enabled" },
    { "field": "identity.lockout_threshold", "op": "gte", "value": 1,
      "label": "Account lockout is enabled" }
  ],
  "remediation": [ "Enforce MFA for all interactive and remote access...", ... ]
}
```

Because the baseline is declarative you can tune it to your own risk appetite - raise the minimum password length, add a check against a field your own tooling emits, or change a severity - without touching the engine. Edit `data/build_baseline.py` and re-run it to regenerate the JSON.

Assessment modes

Not every Annex A control can be measured from a machine. Roughly half are procedural - whether an incident response plan exists, whether staff sign NDAs. The baseline is explicit about which is which, so the tool never pretends to have audited something it cannot see.

Mode	Controls	How the verdict is reached
Automated	20	Decided purely from telemetry. Example: A.8.7 Protection against malware checks that anti-malware is enabled, real-time protection is on, signatures are under three days old, tamper protection is active and at least five ASR rules enforce.
Hybrid	27	Telemetry provides supporting evidence but the control also needs human confirmation. These cap at PARTIAL until an attestation is recorded - the technical control may be present while the surrounding process is not.
Manual	46	Procedural or physical controls decided entirely by auditor attestation, recorded in the app or supplied in the telemetry file. Reported as MANUAL until answered.

Annex A coverage by theme

Theme	Clause	Controls	Representative automated checks
Organizational	A.5	37	Password and lockout policy, dormant accounts, share permissions, log retention, asset inventory completeness
People	A.6	8	Remote-working posture: disk encryption, managed VPN presence, screen lock timeout
Physical	A.7	14	Clear-screen enforcement, off-premises device encryption, TPM presence, removable media control, disk health
Technological	A.8	34	MFA, cryptography, firewall profiles, malware defence, patch currency, audit policy, backup, application control, TLS versions

3. How scoring works

Control statuses

Status	Meaning	Credit
PASS	Every check with usable data was satisfied.	1.0
PARTIAL	Some checks passed, some failed - the control is partially effective. Also applied to a hybrid control whose technical checks pass but has no attestation yet.	0.5
FAIL	No check was satisfied. The control is not effective.	0.0
MANUAL	A procedural control awaiting attestation.	excluded
NO DATA	The telemetry did not contain the fields the control needs - usually an unelevated collector run.	excluded
N/A	Explicitly scoped out by the auditor. Certification requires a documented justification for each exclusion.	excluded

The weighted score

A flat percentage of passed controls would treat a missing clear-desk policy as equal to absent disk encryption. Instead each control carries a weight derived from its inherent severity, so failures on critical controls move the number further:

```
score = SUM(weight x credit) / SUM(weight) x 100

credit : PASS 1.0    PARTIAL 0.5    FAIL 0.0
weight : High 5      Medium 3      Low 1
```

MANUAL and NO DATA controls sit outside the denominator by default, so the score reflects what was actually assessed. Turning on **Strict mode** in the sidebar moves them into the denominator as failures - the conservative posture a certification auditor would take, and a useful worst-case view.

Coverage matters as much as score. The app reports assessment coverage - the share of the 93 controls that produced a real verdict - next to the headline figure. Below 25% it refuses to award a maturity rating and prints a caveat on the PDF cover, because a high score drawn from a handful of controls tells you almost nothing.

Risk levels

A failed control inherits its severity as the open risk level. A partially implemented High severity control steps down to Medium, on the basis that a partially mitigated risk is a smaller risk than an unmitigated one. Passed and scoped-out controls carry no risk.

Maturity bands

Weighted score	Maturity rating
90 - 100%	Optimised - certification ready
75 - 89%	Managed - minor gaps
55 - 74%	Defined - material gaps
35 - 54%	Developing - significant remediation required
Below 35%	Initial - critical exposure

4. Installing and running the web app

Requirements

- Python 3.9 or later on the machine running the app (any OS - Windows, macOS, Linux).
- Windows PowerShell 5.1 or PowerShell 7+ on each host you want to audit.
- No database, no server, no internet connection. Everything runs locally and no telemetry leaves the machine.

Installation

```
cd ISO27001
pip install -r requirements.txt
streamlit run app/main.py
```

On macOS and Linux, `./run.sh` does the same thing but creates an isolated virtual environment first and rebuilds the baseline if you have edited the generator. The app opens at `http://localhost:8501`.

Trying it without a Windows host

Three sample profiles ship with the app. Pick one from the sidebar dropdown and press Load - no collection needed. They are the fastest way to understand what the output looks like at different levels of maturity:

Sample file	Profile	Score	Pass	Gaps	High risk
hardened_server.json	Well-managed Windows Server 2022	83.8%	30	21	0
mixed_endpoint.csv	Partly hardened Windows 11 laptop (CSV)	46.5%	6	41	4
legacy_workstation.json	Neglected Windows 10 workstation	13.4%	0	47	17

Figure 2 - Results produced by the bundled sample profiles.

The five tabs

Tab	What you do there
Dashboard	Read the headline position: compliance gauge, status donut, per-theme bars, a radar against a 75% target, risk histogram and cards for the top six findings.
Control register	All 93 controls, filterable by theme, status and risk and searchable by ID or title. Select any control to see each individual check - the field queried, the rule applied, the value observed - plus its full remediation guidance.
Remediation roadmap	Every gap ordered by risk and grouped into phases, each expandable to reveal the failed checks and numbered technical fixes. Exports to CSV for your ticket system.
Manual attestations	Answer the procedural controls. Results update immediately. Answers export to JSON so the next audit of the same organisation starts where this one finished. Scope exclusions are recorded here too.
Evidence	Every ingested parameter with its value, type and source section - the raw evidence behind each verdict, searchable and exportable.
Export	Build the PDF audit report with selectable sections, or download the register as CSV and the full results as JSON.

5. Collecting telemetry with PowerShell

collector/Collect-ISOTelemetry.ps1 performs a read-only inventory of a Windows endpoint or server and writes a configuration report in the schema the app expects. It changes no setting, installs nothing and opens no outbound connection. Every probe is individually wrapped, so a failure on one item degrades that single value to "not collected" rather than aborting the run.

Basic use

```
# Open PowerShell as Administrator on the target host
Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass -Force
.\Collect-ISOTelemetry.ps1
```

This writes ISOTelemetry_<HOST>_<timestamp>.json and a matching .csv to the current folder. Upload the JSON in the web app - it is the richer of the two.

Run it elevated. Without administrator rights the BitLocker, audit policy, Defender and firewall probes return nothing, and the affected controls report NO DATA. That is the safe behaviour - the tool will not guess - but it leaves you with a materially incomplete audit. The script warns you at startup when it is not elevated.

Parameters

Parameter	Purpose
-OutputPath	Directory for the reports. Created if it does not exist. Defaults to the current folder.
-Format	Json, Csv or Both (default). Use Csv only where tooling cannot handle JSON.
-IncludeAttestations	Adds an empty attestations block to the JSON so an auditor can pre-fill the procedural control answers before uploading.
-ApprovedSoftware	Path to a text file of approved application names, one per line. Anything installed and not on the list is reported as unauthorised software. Without it the script falls back to a built-in list of commonly-flagged remote access and network tools.
-Quiet	Suppresses console output. Use for scheduled or fleet-wide runs.

Auditing a fleet

The script returns the paths it wrote, so it composes in a pipeline. Over WinRM:

```
Get-Content .\hosts.txt | ForEach-Object {
    Invoke-Command -ComputerName $_ -FilePath .\Collect-ISOTelemetry.ps1
}
```

Or as a scheduled task writing to a central share, giving you a rolling record of configuration drift across the estate:

```
.\Collect-ISOTelemetry.ps1 -OutputPath \\fileserver\audit$ -Quiet
```

What it collects

Around 170 parameters across thirteen sections. The pre-flight summary printed at the end flags the headline problems immediately, before you even open the app.

Section	Examples of what is captured
metadata	Hostname, OS caption and build, domain membership, serial number, collection timestamp, whether the run was elevated
identity	MFA providers, local administrator count and membership, password policy, lockout policy, dormant accounts, LAPS, Credential Guard
encryption	BitLocker status and algorithm, key protectors, recovery key escrow, TLS/SSL protocol versions, SMB signing, SMBv1, FIPS mode
logging	Advanced audit policy per subcategory, Security log size and retention, PowerShell script block logging, command-line auditing, SIEM agents, time source and clock offset
endpoint_protection	Defender state, signature age, tamper protection, ASR rule count, EDR presence, firewall profiles, Secure Boot, TPM, UAC, AppLocker/WDAC, USB control, screen lock
patching	Automatic update state, days since last patch, missing critical updates, pending reboot, OS support status, WSUS server
network	RDP and NLA, listening ports, high-risk ports, open shares and 'Everyone' permissions, NetBIOS, LLMNR, DNS servers, VPN presence
backup	Backup product and last successful run, shadow copies, system restore
asset	Installed software inventory, unauthorised software, asset tag and owner, classification labelling, DLP, MDM enrolment
services / configuration	Unnecessary running services, Telnet, Remote Registry, and a computed count of hardening baseline drift items
capacity / hardware	Disk and memory headroom, CPU load, physical disk health

What it deliberately does not collect

Backup encryption, off-site or immutable copies and restore-test recency are not discoverable from a local host - they live in the backup platform. The collector emits them as null so the related controls report NO DATA, and you record the real answer as an attestation. MFA is inferred from installed credential providers, which will miss some third-party products; confirm it by attestation if your MFA solution is not detected.

6. A complete audit, start to finish

- 1 Collect.** On the target host, open PowerShell as Administrator and run `.\Collect-ISOTelemetry.ps1 -IncludeAttestations`. Read the pre-flight summary - it flags missing encryption, absent anti-malware, disabled lockout and missing patches before you go any further.
- 2 Load.** Start the web app, choose the JSON file in the sidebar and press Load. Set the organisation name and the 'Prepared by' field now - both appear on the PDF.

- 3 Read the headline.** The Dashboard gives you the weighted score, the maturity band and the count of open high risks. Check the assessment coverage figure underneath the gauge: if it is low, the collector probably ran unelevated and you should collect again before drawing conclusions.
- 4 Attest.** Open Manual attestations and work through the procedural controls. This is the part only a human can do, and it is where the score becomes representative rather than merely technical. Export your answers to JSON when done - the next audit of the same organisation can import them and start from there.
- 5 Scope.** If a control genuinely does not apply - no in-house development, so the secure coding controls are out of scope - mark it Not Applicable at the bottom of the attestations tab. Certification requires a documented justification for every exclusion, so record yours in the scope statement.
- 6 Investigate.** Use the Control register to examine anything surprising. Each control shows the individual checks, the exact telemetry field queried, the rule applied and the value observed - so a disputed finding can be settled against evidence rather than opinion.
- 7 Plan.** The Remediation roadmap orders every gap by risk and groups it into phases. Phase 1 is your immediate 30-day queue. Expand any item for the numbered technical steps, and export the roadmap as CSV to load into your ticketing system.
- 8 Report.** On the Export tab write a short scope and limitations statement, choose which sections to include and build the PDF. Download the register CSV and results JSON alongside it as your evidence pack.
- 9 Re-audit.** After remediation, collect again and compare. Because the baseline is fixed and the engine is deterministic, the difference in score is a real measure of progress rather than a difference of auditor opinion.

What the exported PDF contains

Section	Contents
Cover	Scorecard with weighted compliance, pass and fail counts, open high risks, a compliance bar, assessment metadata and your scope statement
1. Executive summary	Narrative of the result, how the score was derived, the open risk profile and a status distribution table
2. Compliance by theme	Per-theme table and bars, plus the highest-impact open findings
3. Control register	All 93 controls with theme, mode, status, risk and checks passed
4. Remediation roadmap	Prioritised summary with target windows
5. Technical detail	Failed checks and numbered fix steps for the top findings
Appendix A	The telemetry parameters that constitute the evidence base

7. Troubleshooting

Symptom	Cause and resolution
Many controls show NO DATA	The collector ran without administrator rights, so the BitLocker, audit policy, Defender and firewall probes returned nothing. Re-run PowerShell elevated. Check the <code>metadata.collected_elevated</code> field in the Evidence tab to confirm.
Score looks implausibly high	Check assessment coverage on the Dashboard. A high score from a small assessed pool is not meaningful - the app warns when coverage drops below 50%. Record attestations, or enable Strict mode to see the worst case.
'Could not parse the file'	The uploaded file is not valid JSON, or the CSV lacks a recognised layout. CSV must be either key/value columns or one header row of dotted keys plus one data row. Re-run the collector rather than hand-editing the report.
A control passes that should not	Open it in the Control register and read the individual checks - the observed value is shown for each. If the baseline is too permissive for your risk appetite, tighten the check in <code>data/build_baseline.py</code> and re-run it.
MFA reported as absent	MFA is inferred from installed credential providers and will miss some third-party products. Confirm the real position and record it as an attestation.
Script blocked from running	PowerShell execution policy. Run <code>Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass -Force</code> first; this affects only the current session.
PDF build fails	Ensure <code>fpdf2</code> is installed, not the abandoned <code>fpdf</code> package: <code>pip uninstall fpdf && pip install fpdf2</code> .

8. Limitations and honest caveats

It is worth being clear about what this tool is and is not, because overstating an automated result is the fastest way to fail a real certification audit.

- **This is a technical configuration assessment, not an ISMS audit.** ISO/IEC 27001 certification assesses a management system - clauses 4 to 10 cover context, leadership, planning, risk treatment, competence and continual improvement. None of that is in Annex A, and none of it is measurable from a registry key. The tool supports certification work; it does not substitute for it.
- **It audits one host at a time.** A clean result on one server says nothing about the other forty. Collect across the estate and treat each report as one sample.
- **Point-in-time evidence.** Configuration drifts. A report is accurate for the moment it was collected and no longer.
- **Detection heuristics are imperfect.** MFA, DLP, EDR and backup products are identified by service names and registry markers. A product the heuristic does not recognise will be reported as absent - verify by attestation.
- **Attestations are self-reported.** The tool records what an auditor asserts; it cannot verify it. For certification, back each attestation with documented evidence.
- **The baseline reflects a defensible interpretation, not the standard's text.** ISO 27001 states control objectives, not specific thresholds. The decision that passwords must be 14 characters, or signatures under three days old, is a judgement drawn from CIS and Microsoft security baselines. Your certification body may take a different view; the baseline is editable for exactly that reason.

In short: use this tool to find and fix technical gaps quickly, to track measurable progress between audits, and to arrive at a certification audit with the configuration evidence already assembled. Do not present its score as a statement of ISO 27001 compliance.